

Étude de cas : Fuite de données chez FinancePlus

Contexte :

FinancePlus est une PME spécialisée dans les services financiers. Elle dispose d'un petit service informatique (4 personnes), d'environ 200 employés, et utilise un mix de services en cloud (Office 365, CRM SaaS) et d'applications hébergées sur un serveur interne (ERP maison, fichiers partagés).

Un matin, l'équipe IT découvre que des fichiers confidentiels (rapports d'audit, prévisions budgétaires) ont été exfiltrés pendant le week-end. L'analyse révèle qu'un compte utilisateur d'un employé récemment parti a été compromis. Ce compte n'avait pas été désactivé, et aucune alerte n'a été déclenchée.

Éléments connus :

Le compte compromis avait accès à plusieurs partages réseau non segmentés.

Aucun MFA n'était activé sur les connexions internes.

Les journaux d'accès sont incomplets (pas de SIEM centralisé).

L'accès à distance aux applications internes se faisait via un VPN générique (un seul identifiant partagé entre plusieurs utilisateurs).

Il n'y avait pas de contrôle de conformité des appareils.

Question

1. Quelles failles de sécurité avez-vous identifiées dans cette situation ? Vous devez fournir les éléments de réponse sous forme de tableau

Élément concerné		Problème identifié Impact potentiel Cause principale	
Compte inactif non	fermé	Exfiltration de	processus RH/IT
	Compromission possible post-départ	données	
VPN générique Pas de	traçabilité individuelle	Manque de	Partage de credentials
	Accès non maîtrisé		
... ..			

2. Comment le modèle Zero Trust aurait-il pu prévenir cette fuite de données ?
3. Quels principes du Zero Trust devraient être prioritaires pour FinancePlus ?

4. Quels outils ou solutions techniques pouvez-vous recommander à une PME avec des ressources limitées ?

5. Proposez une feuille de route de 3 étapes pour entamer la transition vers un modèle Zero Trust.

Il s'agit de proposer 3 grandes **étapes progressives** pour aider une PME à amorcer la mise en place du modèle Zero Trust, sans tout faire d'un coup.

une "feuille de route", c'est le "comment" on va mettre en œuvre, pas le "pourquoi". 2

